PIC – Enterprise Admin Module (M13) Analysis Against the Technical Document and Blueprint

Date: 1 November 2026. Written for: the product owner. Scope: Blueprint Module M13 "Platform, Workflow & Administration" (screens ADM-01 to ADM-06) and the matching Technical Document requirements (tenancy, identity, SoD, rules, workflow, integration, audit, privacy).

Method: the Blueprint and Technical Document text were read against the code (API routes in `backend/app/pic/api`, services, models, the admin screen in `frontend/src/app/pic/admin`). This is a code-level reading. The integrated test suite was still running when this was written, so nothing below says "verified working by test"; section 4 says what will confirm it.

1. What the specification requires

Blueprint M13 capabilities: (1) org model tenant, legal entity/company code, plant, storage location, purchasing org/group; (2) rule engine for thresholds, mandatory fields, tolerances; (3) BPMN workflow designer and approval matrix; (4) roles, permissions, SoD rule set and conflict reports; (5) integration hub with ERP connectors, mappings, monitoring, replay; (6) audit explorer and data retention; (7) industry template packs. Business rules: rule changes are versioned and effective-dated and in-flight documents keep their rule version; workflow models are versioned and running instances finish on their version.

Screens: ADM-01 Organisation & Tenant Setup (org structure, currencies, calendars), ADM-02 Rules & Thresholds, ADM-03 Workflow & Approval Designer (BPMN models, approval matrix, simulation), ADM-04 Roles & SoD, ADM-05 Integration Monitor (message flows, errors, replays, reconciliation), ADM-06 Audit Explorer. KPIs: integration success %, mean time to resolve integration error, SoD conflicts open.

Technical Document: tenant from token, never payload; RLS; SSO via SAML/OIDC; MFA for admins; RBAC plus ABAC; SoD engine at command time; 10-year configurable audit retention; DPDP privacy (retention, export, erasure).

2. Status by capability

Capability	Status	Evidence	Gap
Rule sets, effective dating, versions, simulation (ADM-02, ADM-03 simulation)	Built	`POST /admin/rules`, `/admin/rules/simulate`, `rule_set_version` stored on documents, mandatory-fields editor	None found at code level
BPMN designer, versioned process definitions (ADM-03)	Built (new, unverified)	`/process-definitions/*` with draft, validate, publish, retire, diff, BPMN parse	Not yet tested by me end to end
Roles, SoD rules and violations, SoD mitigations (ADM-04)	Partly built	`/admin/roles`, `/admin/sod`, `PUT /admin/sod/{code}`, mitigations	Roles are fixed in code (`ROLE_SCOPES`): no custom roles, no permission-matrix editing
Integration monitor, replay, connectors, mappings, ERP sync (ADM-05)	Built	`/integration/messages`, replay, `/admin/connectors`, field mappings, ERP sync	Not tested end to end
Audit explorer, hash-chain verify, archive, retention and privacy tools (ADM-06)	Built	`/audit`, `/audit/verify`, `/admin/audit/archive`, `/admin/privacy/*`	Not tested end to end
Scheduled jobs, delegations, AI switch	Built (new)	`/admin/jobs`, `/admin/delegations`, `/admin/ai/switch`	Built by an agent that stalled without reporting; unverified
Organisation setup (ADM-01)	**Read-only**	`GET /admin/organisation` only	No create or edit for company codes, plants, storage locations, cost centres/WBS, calendars or holidays, currencies. Only FX rates can be added. The holiday function exists in the service but has no route.
Purchasing organisation and purchasing group	**Missing**	No master tables or screens	Named in the Blueprint org model
User lifecycle (ADM-04)	**Partly built**	List users, set roles, activate/deactivate, reset MFA	No way to create or invite an internal user, no admin password reset, no session revocation, no bulk import. Users exist only from seed and supplier invitations.
Industry template packs	**Read-only**	`GET /admin/templates`	Cannot preview or apply a template or its rule sets to a tenant from the admin screen
Tenant provisioning	**Missing**	Tenants are created by seed scripts only	No repeatable way to create a tenant with org, admin user and template
Approval matrix editor (ADM-03)	**Unconfirmed**	Matrix lives inside the DMN-01 rule body; simulation exists	No dedicated grid editor; to be confirmed on the screen
Admin KPIs (integration success %, mean time to resolve, open SoD conflicts)	**Unconfirmed**		To be confirmed on the screen and in the KPI registry

3. Does the complete admin workflow work?

Not yet, on two counts.

1. **The workflow a new customer needs cannot be done from the product.** An administrator cannot set up the organisation (companies, plants, storage locations, cost centres, calendars, purchasing orgs), cannot add an internal user, and cannot apply a template. Today all of that happens in seed scripts. That is the real break in the end-to-end admin flow: create tenant, build org, add users and roles, apply template, set rules, then operate.
2. **Roles cannot be tailored.** Enterprise customers need custom roles and visible permission matrices; the code has a fixed role list.

The review, rule, workflow, integration and audit parts exist. Whether they work together is for the tests in section 4 to say.

4. How it will be verified

- The admin-related existing tests (`test_platform_ops` , `test_review_platform` , `test_wave1_platform` , `test_production` , `test_order_ops` , `test_intelligence_modules`) are in the integrated backend run now in progress. The result goes in the final report.
- A scripted API walkthrough of the whole admin journey on a scratch database, after the build below: create tenant, org, users and roles, template, rule version with effective date, workflow publish, SoD conflict, integration failure and replay, audit verify.
- One browser pass of the admin screens on the integrated build.

5. Build plan to reach enterprise grade

One engineer (not several in parallel), because these files overlap and the earlier parallel run showed the cost of that.

1. **Organisation management (ADM-01):** create, edit and deactivate company codes, plants, storage locations, cost objects, calendars and holidays, currencies; new `purchasing_org` and `purchasing_group` tables. Deactivate instead of delete when a record is referenced. Audited, versioned (ETag), idempotent.
2. **User lifecycle:** invite or create internal users with roles and attributes (plant, company, value limit), single-use activation link, admin-triggered password reset, session revoke, bulk import by CSV with a dry run, SoD check on role assignment.
3. **Custom roles and permission matrix:** read-only built-in roles plus tenant-defined roles with chosen scopes, a matrix screen, and SoD impact shown before saving.
4. **Template packs:** preview what a template would change, apply it idempotently, record who applied it.
5. **Tenant provisioning:** a command-line tool (no public API) that creates a tenant with base org, first admin and template. Keeping it off the web API is deliberate: it needs platform-level authority that no tenant role should have.
6. **Admin KPIs and approval-matrix grid** if the screen check shows they are missing.
7. Tests for each, one new migration, an admin runbook, and updated docs.

6. Decisions taken

- Custom roles cannot hold platform-level scopes or weaken SoD pairs; a custom role that would create an SoD conflict is refused.
- Tenant provisioning stays a command-line tool.
- Existing data is not changed; the new work only adds tables, routes and screens.

7. What I need from you

Nothing blocks this. Two things for the live setup, not for the build: the identity-provider details (SAML/OIDC) if you want single sign-on for admins, and the initial customer organisation data (company codes, plants, cost centres, purchasing orgs) when a real client is onboarded.